UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

PLAN DE RESPUESTA ANTE INCIDENTES DE CIBERSEGURIDAD

PR02 – Blindando la información: gobernanza y cumplimiento

FECHA DE ENTREGA:16 DE OCTUBRE 2026

ALUMNO: DAVID CAMPOS MORADO – 183511
PROFESOR: MTRO. SERVANDO LÓPEZ CONTRERAS

Propósito, alcance y clasificación

Propósito: Establecer la estrategia, roles, procedimientos y playbooks que permitan a INTERAFAS detectar, analizar, contener, erradicar y recuperarse de incidentes de ciberseguridad de manera oportuna, eficaz y coordinada, minimizando el impacto sobre la infraestructura crítica, los ciudadanos y la reputación institucional.

Alcance: Aplicable a todos los sistemas de información, redes IT y OT, personal y terceros que participen en la operación de INTERAFAS. Cubre incidentes que afecten confidencialidad, integridad o disponibilidad de la información o del proceso físico.

Concepto de incidente: Evento no deseado o inesperado que tiene probabilidad significativa de comprometer las operaciones y amenazar la seguridad de la información o del proceso.

Clasificación de severidad

- Baja: Impacto limitado, sin afectación a ciudadanos ni al proceso físico; manejable por el equipo de soporte.
- Media: Afectación a sistemas no críticos o datos limitados; requiere activación del equipo de respuesta.
- Alta: Compromiso de sistemas críticos, datos personales o posibilidad de impacto en el proceso; activa Comité de Crisis.
- Crítica: Impacto confirmado o inminente en el proceso físico, servicios esenciales o crisis reputacional mayor.

Prioridades de activación: Protección de la vida y del proceso físico > Contención de la amenaza > Preservación de evidencia > Recuperación de servicios > Comunicación.

Roles y responsabilidades

- Líder de Respuesta a Incidentes (Incident Commander): Coordina la respuesta global, toma decisiones de escalamiento y reporta a la Alta Dirección.
- Responsables técnicos (IT / OT): Ejecutan contención, análisis forense, erradicación y recuperación en sus respectivos dominios.
- CISO / Seguridad de la Información: Asesora, asegura la correcta clasificación y la preservación de evidencia, coordina con autoridades.
- Comunicación / Vocería: Gestiona la comunicación interna y externa según el Plan de Comunicación de Crisis.
- Jurídico: Asesora sobre obligaciones de notificación, preservación de evidencia y aspectos legales.
- Dirección / Alta Dirección: Autoriza decisiones de alto impacto (apagado de sistemas, comunicación pública, notificación a autoridades).
- Terceros (proveedores, CSIRT externos): Se involucran según contratos y necesidad técnica.

Preparación, detección y reporte

reparación

- Mantener inventarios actualizados de activos críticos (IT y OT).
- Definir y probar canales de reporte de incidentes (correo, teléfono, ticket, botón de pánico en HMI).
- Realizar ejercicios y simulacros periódicos (tabletop y técnicos).
- Mantener playbooks actualizados y accesibles offline.

Detección y fuentes

- Alertas de SIEM / monitoreo de seguridad.
- Reportes de usuarios y personal de operaciones.
- Anomalías en telemetría OT y HMI.
- Notificaciones de terceros o autoridades.

Reporte

Todo evento sospechoso debe reportarse de inmediato al canal definido. El reporte inicial debe incluir: quién reporta, qué se observó, cuándo, sistemas afectados y acciones ya tomadas.

Análisis y priorización (Triage)

- Validación: confirmar que se trata de un incidente real y no de un falso positivo.
- Alcance: determinar sistemas, datos y procesos afectados.
- Clasificación de severidad según la escala definida.
- Prioridad: asignar recursos según impacto y urgencia.
- Preservación de evidencia: desde el primer momento (logs, imágenes de memoria, capturas, cadenas de custodia).
- Escalamiento: notificar al Líder de Respuesta y, si corresponde, al Comité de Crisis y a la Alta Dirección.

Contención

Objetivo: limitar la propagación del incidente y reducir el daño, preservando evidencia y manteniendo la continuidad operativa en la medida de lo posible.

- Contención inmediata: aislamiento de hosts/segmentos comprometidos, bloqueo de cuentas, deshabilitación de servicios vulnerables.
- Contención prolongada: medidas temporales más estables mientras se prepara la erradicación (reglas de firewall, segmentación adicional, monitoreo reforzado).
- Consideraciones OT: en entornos de control, priorizar la seguridad del proceso físico; evitar acciones que puedan causar estados inseguros.

Erradicación y remediación

- Eliminación de la causa raíz (malware, cuentas comprometidas, vulnerabilidades explotadas).
- Corrección de vulnerabilidades (parches, cambios de configuración, eliminación de backdoors).
- Verificación de que no persisten mecanismos de persistencia.
- Validación de controles antes de declarar la fase de recuperación.

Recuperación

- Restauración segura de sistemas desde respaldos verificados o reconstrucción limpia.
- Pruebas de funcionalidad y de seguridad antes de reintroducir sistemas a producción.
- Monitoreo reforzado durante el periodo de recuperación.
- Criterios de retorno a operación normal: ausencia de indicadores de compromiso, controles restaurados, aprobación del Líder de Respuesta.
- Mecanismos de rollback documentados en caso de que la recuperación presente problemas.

Coordinación y comunicación

La respuesta técnica se coordina permanentemente con el Plan de Comunicación de Crisis. Se establecen puntos de contacto claros entre el equipo de respuesta, la vocería, la dirección, el área jurídica y las autoridades externas. Todo escalamiento ejecutivo se registra.

Playbooks operativos

Se definen los siguientes playbooks derivados de los escenarios observados en INTERAFAS-LAB. Cada playbook incluye: disparador, responsables, acciones de contención, evidencia a preservar, recuperación y criterio de cierre.

Playbook 1 – Compromiso de datos de ciudadanos (IDOR / SQLi / exposición)

- Disparador: detección de acceso no autorizado a expedientes o extracción de datos personales.
- Acciones: contención de la vulnerabilidad, revisión de logs de acceso, notificación a afectados y autoridades según ley, comunicación coordinada.
- Evidencia: logs de aplicación y base de datos, capturas de peticiones, cadena de custodia.

Playbook 2 – Escalamiento de privilegios / sesión comprometida

- Disparador: uso de cookies o tokens robados, roles elevados indebidamente.
- Acciones: invalidación masiva de sesiones, rotación de secretos, revisión de cuentas privilegiadas, contención de cuentas sospechosas.

Playbook 3 – Incidente en pasarela de pagos / lógica de negocio

- Disparador: transacciones anómalas, manipulación de montos, sospecha de fraude.
- Acciones: suspensión temporal del canal de pago si es necesario, conciliación, preservación de logs de transacciones, comunicación con entidad financiera.

Playbook 4 – Compromiso del canal de firmware / configuración OT

- Disparador: detección de carga de firmware o configuración no firmada, modificación de setpoints críticos.
- Acciones: aislamiento del segmento afectado si es seguro, reversión a configuración conocida buena, verificación de integridad de todos los dispositivos, activación de safe-mode si existe.
- Criterio de cierre: dispositivos verificados, firmas validadas, monitoreo reforzado activo.

Playbook 5 – Movimiento lateral / bypass de segmentación OT

- Disparador: detección de tráfico anómalo desde IT hacia OT o uso de cabeceras spoofeadas.
- Acciones: refuerzo inmediato de reglas de segmentación, análisis de alcance, caza de amenazas en ambos dominios, revisión de cuentas de servicio.

Playbook 6 (adicional) – Crisis reputacional asociada a incidente técnico

- Disparador: cobertura mediática o viralización de un incidente de seguridad.
- Acciones: activación conjunta del Plan de Comunicación de Crisis y del equipo de respuesta técnica; mensajes coordinados; priorización de contención técnica que permita comunicar hechos verificados.

Post-incidente y mejora

Al cierre de todo incidente de severidad Media o superior se realizará:

- Informe final de incidente (línea de tiempo, impacto, causa raíz, acciones tomadas, lecciones aprendidas).
- Reunión de lecciones aprendidas (post-mortem) con los roles involucrados.
- Actualización de playbooks, procedimientos y controles.
- Seguimiento de acciones correctivas hasta su cierre, con responsables y fechas.
- Métricas: tiempo de detección, tiempo de contención, tiempo de recuperación, número de sistemas afectados, efectividad de los playbooks.

Las lecciones aprendidas alimentan el ciclo de mejora continua del SGSI y de este Plan de Respuesta ante Incidentes.